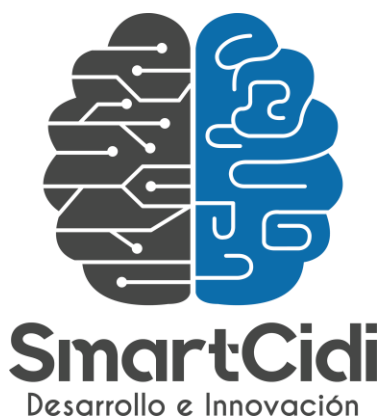




Reporte Ejecutivo de Diagnóstico de Madurez Sistema de Gestión de Protección de Datos Personales

Assessment preliminar - LOPDP Ecuador

Cooperativa evaluada	Cooperativa de Ahorro y Crédito Padre Julián Lorente Ltda.
Segmento	Segmento 1 - confirmado en segmentación SEPS 2026
Fecha del assessment	15 de septiembre de 2026
Participantes entrevistados	Subgerencia de TI, Seguridad de la Información y Dirección Jurídica
Duración aproximada	1 hora
Base de evaluación	Entrevista diagnóstica de carácter exploratorio. Por el alcance del ejercicio no se solicitó validación documental ni se ejecutaron pruebas técnicas.
Versión del reporte	v1.3 - Documento técnico-consultivo SMARTCIDI

Este documento presenta una radiografía preliminar del estado del Sistema de Gestión de Protección de Datos Personales, construida a partir de la información proporcionada durante una sesión diagnóstica de cortesía. Su propósito es identificar fortalezas, áreas que requieren mayor profundidad y prioridades para una siguiente fase. No constituye una auditoría de cumplimiento, certificación ni dictamen legal definitivo. La validación del diseño, implementación y eficacia de los controles corresponde a una auditoría posterior basada en evidencia, muestreo y pruebas técnicas.

Preparado por SMARTCIDI | Ecuador | 2026

1. Resumen ejecutivo

El assessment realizado a la Cooperativa constituye una radiografía inicial del estado percibido de su Sistema de Gestión de Protección de Datos Personales. A partir de las respuestas recogidas durante la sesión, la matriz calcula una madurez global ponderada de 81,02%, equivalente teóricamente a un Nivel 4 - Gestionado. No obstante, el modelo identifica cuatro controles estructurales prioritarios con nivel bajo, lo que ajusta el resultado general a Nivel 2 - Básico / Repetible, condicionado por brechas estructurales. Este ajuste no debe interpretarse como una conclusión definitiva de cumplimiento, sino como una señal de los ámbitos que requieren mayor profundidad.

El ejercicio fue concebido como un assessment preliminar de cortesía y alcance exploratorio. Por diseño, no contempló la solicitud ni revisión de políticas, RAT, contratos, registros, configuraciones, logs, EIPD, actas u otras evidencias, ni la ejecución de pruebas técnicas. Por tanto, los resultados reflejan una fotografía orientativa basada en la información proporcionada por los participantes y sirven principalmente para priorizar la siguiente fase de evaluación.

Score ponderado del archivo	Resultado final ajustado
81,02% Resultado orientativo calculado por la matriz	Nivel 2 Básico / Repetible, condicionado por brechas estructurales
Brechas críticas	Brechas altas
11 1 requiere revalidación sectorial	4 Prioridad de corto plazo
Controles estructurales prioritarios	Cobertura registrada
4 Inventario, RAT, datos sensibles e identidad	80 / 80 Todos marcados como aplicables

1.1 Resultado de la valoración

- Las respuestas recogidas muestran una percepción de madurez favorable: 57 de 80 controles fueron ubicados en Nivel 5 y 56 de 80 registraron Nivel de Evidencia 4 en la matriz.
- El assessment identifica áreas estructurales que requieren atención prioritaria: inventario de tratamientos, RAT, identificación de datos sensibles o de mayor riesgo, conservación, actualización del RAT, verificación de identidad en derechos, gestión de incidentes y mejora continua.
- Se observan diferencias de madurez entre controles estrechamente relacionados: algunos aparecen en niveles avanzados mientras otros controles habilitadores se encuentran en etapas iniciales. Estas diferencias no invalidan las respuestas ni constituyen por sí mismas un hallazgo de incumplimiento; sirven para orientar el alcance, muestreo y pruebas de una auditoría posterior.

- Para una entidad financiera de Segmento 1, el siguiente nivel de aseguramiento debería obtenerse mediante revisión documental, evidencia operativa y pruebas técnicas sobre los controles que soportan la trazabilidad, la gestión de riesgos, el rol del DPD y los tratamientos de mayor impacto.

Conclusión ejecutiva

El assessment permite identificar fortalezas percibidas y áreas prioritarias de profundización en la Cooperativa. Por su naturaleza exploratoria, no fue diseñado para confirmar documentalmente el cumplimiento ni la eficacia de los controles. Su principal valor es ofrecer una radiografía de partida que permita enfocar la siguiente fase. Se recomienda realizar una Auditoría de Cumplimiento LOPDP basada en evidencia y, de forma complementaria, una evaluación de los controles de seguridad aplicables tomando ISO/IEC 27002:2022 como marco técnico de referencia.

2. Alcance, metodología y naturaleza del ejercicio

2.1 Cómo se realizó el assessment

- Entrevista de aproximadamente una hora con representantes de Tecnología de la Información, Seguridad de la Información y Jurídico, realizada como ejercicio diagnóstico preliminar de cortesía.
- Análisis de 80 controles distribuidos en 10 dimensiones del SGPDP.
- Los valores de las columnas K (Nivel asignado) y L (Nivel evidencia) fueron utilizados para el cálculo del archivo fuente.
- Por el alcance exploratorio definido para esta fase, no se contempló revisión documental, observación de configuraciones, muestreo de expedientes, entrevistas adicionales, pruebas de efectividad ni contraste con terceros.

2.2 Naturaleza y alcance del diagnóstico

El assessment fue diseñado para obtener una visión inicial del estado de madurez a partir de entrevistas y respuestas registradas en la matriz. En esta fase no correspondía solicitar ni corroborar evidencia documental u operativa. En consecuencia, los niveles de evidencia consignados deben entenderse como información reportada por los participantes y como insumo para definir qué documentos, registros y controles conviene revisar en una auditoría posterior.

3. Resultado por dimensión

Los porcentajes siguientes reproducen el resultado calculado por la matriz y deben interpretarse como indicadores orientativos de madurez derivados del assessment. No equivalen a un porcentaje de cumplimiento auditado; su utilidad es identificar fortalezas percibidas y áreas que requieren mayor profundidad.

Dimensión	Score	Nivel	C/A	Lectura para profundización
Gobierno y responsabilidad proactiva	79.4%	Nivel 4	0/2	Percepción favorable de gobierno; conviene profundizar la gestión documental y los indicadores a dirección.

Dimensión	Score	Nivel	C/A	Lectura para profundización
Inventario, RAT, finalidades y legitimación	50.3%	Nivel 2	5/0	Dimensión estructural prioritaria: inventario, RAT, datos sensibles, conservación y actualización.
Transparencia e información al titular	97.5%	Nivel 5	0/0	Puntaje alto; conviene validar cobertura y consistencia una vez consolidado el inventario y el RAT.
Derechos de titulares	80.0%	Nivel 4	1/1	Procedimiento reportado con madurez alta; la verificación de identidad y las pruebas de extremo a extremo requieren profundización.
Procesos críticos y ciclo de vida de datos	91.1%	Nivel 5	1/0	Puntaje alto; conviene remapear los controles a procesos financieros y realizar muestreo sectorial.
Encargados, proveedores y transferencias	92.6%	Nivel 5	0/0	Madurez reportada alta; la auditoría deberá revisar contratos, DPA, subencargados, nube y salida de proveedores.
Seguridad de datos personales	85.6%	Nivel 4	0/0	Madurez reportada alta; la siguiente fase permitirá revisar configuraciones, logs y muestras de efectividad.
Incidentes y vulneraciones	74.1%	Nivel 3	2/1	Se reportan procedimientos relevantes; conviene profundizar severidad, preservación de evidencia y simulacros.
Riesgos, EIPD, LIA y privacidad desde el diseño	95.7%	Nivel 5	0/0	Puntaje muy alto; la auditoría deberá comprobar su trazabilidad con el inventario y el RAT.
Capacitación, cultura, auditoría y mejora continua	69.3%	Nivel 3	2/0	Áreas de mejora en campañas, seguimiento de acciones correctivas y revisión por dirección.

Las dimensiones con puntajes más altos no pueden analizarse de forma aislada. En particular, una gestión de riesgos/EIPD cercana al 96% y una transparencia cercana al 98% deben poder trazarse a un inventario de tratamientos, RAT, clasificación de datos, bases de legitimación y conservación. Esa trazabilidad no quedó demostrada en el assessment.

Los puntajes más altos deben leerse como señales de madurez percibida y no como una conclusión sobre eficacia. En particular, la gestión de riesgos/EIPD y la transparencia deberían poder relacionarse con inventario de tratamientos, RAT, clasificación de datos, bases de legitimación y conservación. Esa trazabilidad constituye un punto natural de revisión en la siguiente fase de auditoría.

4. Áreas de profundización para la siguiente fase

El análisis pregunta por pregunta permite identificar relaciones entre controles que conviene revisar con mayor profundidad. Estas observaciones no implican que las respuestas sean incorrectas ni constituyen hallazgos definitivos de incumplimiento; orientan el alcance, el muestreo y las pruebas que deberían ejecutarse en una auditoría posterior.

Tema relacionado	Observación	Validación sugerida en auditoría
Nivel de evidencia registrado vs. alcance del assessment	La matriz registra 56 controles con nivel de evidencia 4/4. Dado el alcance exploratorio, esa evidencia no fue solicitada ni revisada en esta fase.	Revisar una muestra representativa para confirmar vigencia, aprobación, aplicación y trazabilidad.
Inventario/RAT vs. finalidades, bases y transparencia	La matriz ubica inventario y RAT en 1/5 con evidencia 0; a la vez, finalidades, bases de legitimación y transparencia aparecen en niveles altos.	Verificar en auditoría cómo se asegura la cobertura integral de avisos y bases de legitimación sobre el universo real de tratamientos.
Riesgos/EIPD vs. inventario de tratamientos	Riesgos/EIPD registra 95,7%, mientras Inventario/RAT registra 50,3%.	Muestrear EIPD y matrices de riesgo y revisar su vinculación con tratamientos reales, responsables, datos, sistemas y riesgo residual.
Auditoría interna vs. mejora continua	La auditoría/revisión interna se reporta en 5/5 con evidencia 4, mientras que el seguimiento de acciones y la revisión por dirección se encuentran en 1/5.	Revisar informe de auditoría, plan de acciones, responsables, cierres y actas de revisión por dirección.
Gestión de incidentes	Se reportan procedimientos, registros y criterios de notificación; clasificación de severidad y preservación de evidencia están en 1/5 y no se registran simulacros.	Ejecutar prueba de escritorio y revisar casos o tickets para comprobar el flujo de decisión y la conservación de evidencia.
Derechos de titulares	Procedimiento y registro se reportan en 5/5, mientras la verificación de identidad está en 1/5.	Muestrear solicitudes atendidas y revisar controles de identidad y representación para reducir el riesgo de divulgación indebida.

5. Brechas prioritarias

5.1 Cuatro controles estructurales prioritarios que condicionan la madurez

ID	Control	Riesgo	Acción prioritaria
9	Inventario de tratamientos de la empresa	Crítico	Levantar o actualizar inventario de tratamientos con dueños por proceso.
10	Registro de Actividades de Tratamiento (RAT)	Crítico	Construir o actualizar RAT con base en procesos reales y evidencia de validación.
13	Datos sensibles y datos personales de mayor riesgo	Crítico	Clasificar datos sensibles y definir controles reforzados por tratamiento.
28	Verificación de identidad	Crítico	Definir criterios de verificación de identidad y representación.

5.2 Brechas críticas y altas del archivo fuente

ID	Dimensión	Control	Riesgo	Observación de auditoría
7	Gobierno y responsabilidad proactiva	Gestión documental del SGPDP	Alto	El control documental debe probar versión, dueño, aprobación, vigencia y repositorio.
8	Gobierno y responsabilidad proactiva	Indicadores y reportes a dirección	Alto	Solicitar dashboard/KPI y actas de revisión; la falta de indicadores contradice un nivel gestionado.
9	Inventario, RAT, finalidades y legitimación	Inventario de tratamientos de la empresa	Crítico	Base habilitadora. Debe cubrir todos los procesos, sistemas, titulares, terceros y ubicaciones.
10	Inventario, RAT, finalidades y legitimación	Registro de Actividades de Tratamiento (RAT)	Crítico	Base habilitadora. Verificar RAT completo, validado por áreas y actualizado.

ID	Dimensión	Control	Riesgo	Observación de auditoría
13	Inventario, RAT, finalidades y legitimación	Datos sensibles y datos personales de mayor riesgo	Crítico	Identificar datos crediticios, biometría, menores u otras categorías especiales cuando apliquen; asociar controles reforzados.
14	Inventario, RAT, finalidades y legitimación	Plazos de conservación	Crítico	Definir y justificar retención, bloqueo, eliminación/anonimización y tratamiento de respaldos.
16	Inventario, RAT, finalidades y legitimación	Actualización del RAT por cambios	Crítico	Formalizar disparadores de actualización ante nuevos procesos, sistemas, proveedores o finalidades.
28	Derechos de titulares	Verificación de identidad	Crítico	Riesgo directo de confidencialidad al atender derechos. Validar identidad/representación de forma proporcional.
32	Derechos de titulares	Prueba o simulación de atención de derechos	Alto	La ausencia de pruebas impide conocer si el procedimiento funciona de extremo a extremo.
39	Procesos críticos y ciclo de vida de datos	Logística, despacho, entrega y retiro	Crítico	El control proviene del modelo comercial y debe revalidarse/reformularse al contexto financiero; no usar como hallazgo definitivo sin esa validación.
59	Incidentes y vulneraciones	Clasificación de severidad	Crítico	Sin severidad definida, puede fallar el escalamiento y la evaluación de notificación.

ID	Dimensión	Control	Riesgo	Observación de auditoría
61	Incidentes y vulneraciones	Contención y preservación de evidencia	Crítico	Preservación de logs y evidencias es necesaria para análisis, contención y trazabilidad.
63	Incidentes y vulneraciones	Pruebas o simulacros tabletop	Alto	La ausencia de simulacros reduce capacidad de demostrar respuesta efectiva.
79	Capacitación, cultura, auditoría y mejora continua	Seguimiento de acciones correctivas	Crítico	Sin seguimiento formal no se puede cerrar ni demostrar corrección de hallazgos.
80	Capacitación, cultura, auditoría y mejora continua	Mejora continua y revisión por dirección	Crítico	La falta de revisión por dirección limita responsabilidad proactiva y mejora continua.

6. Riesgos ejecutivos derivados

- **Responsabilidad proactiva y demostrabilidad:** La Cooperativa podría disponer de controles que no estén suficientemente trazados o respaldados ante una revisión del Directorio, auditoría, autoridad o titular.
- **Licitud, transparencia y coherencia del tratamiento:** Sin inventario y RAT consolidados no es posible demostrar que finalidades, bases de legitimación, avisos, proveedores, transferencias y conservación cubren el universo real de tratamientos.
- **Derechos y confidencialidad:** Una verificación de identidad insuficiente puede generar divulgación indebida o respuestas defectuosas a solicitudes de titulares.
- **Incidentes y resiliencia:** La falta de criterios de severidad, preservación de evidencia y simulacros puede afectar la capacidad de clasificar, contener, decidir y demostrar una respuesta oportuna.
- **Conservación y eliminación:** La ausencia de una tabla de retención y de reglas comprobables de eliminación/bloqueo incrementa exposición por sobreconservación, copias y respaldos.
- **Terceros, nube y transferencias:** La madurez reportada en el assessment debería profundizarse mediante revisión de proveedores críticos, contratos, subencargados, accesos de soporte, ubicación, salida y destrucción de información.
- **Riesgo de interpretación del diagnóstico:** El porcentaje obtenido en el assessment no debe asimilarse a un porcentaje de cumplimiento. Su utilidad es orientar prioridades; la auditoría posterior permitirá confirmar diseño, implementación y eficacia de los controles relevantes.

7. Interpretación para la Cooperativa Padre Julián Lorente

- La condición de Segmento 1 fue confirmada en la segmentación oficial vigente de la SEPS para 2026. El segmento no crea por sí solo un 'nivel de madurez legal', pero sí es un indicador de escala operativa y justifica un enfoque de aseguramiento más profundo.
- Los tratamientos habituales de una institución financiera pueden calificarse como tratamiento a gran escala conforme al marco ecuatoriano vigente, por lo que el gobierno del DPD y las obligaciones reforzadas deben verificarse expresamente.
- La auditoría debe centrarse en tratamientos reales del negocio financiero: vinculación y actualización de socios/clientes, captaciones, crédito, garantes, cobranzas, prevención de fraude, canales digitales, core, videovigilancia/biometría si aplica, talento humano, proveedores, reportes y transferencias.
- La eficacia de seguridad debe probarse mediante evidencia técnica: identidades, privilegios, MFA, registros, respaldos, restauraciones, vulnerabilidades, cifrado, accesos de soporte y gestión de bajas.
- Las EIPD, LIA y evaluaciones de riesgo deben poder trazarse a un tratamiento específico y a decisiones documentadas, no solo a formatos o metodologías generales.

8. Recomendación: Auditoría de Cumplimiento LOPDP

Recomendación principal

Ejecutar, como siguiente fase, una auditoría basada en evidencia que utilice este assessment como mapa de priorización. El objetivo es evolucionar de una radiografía inicial a una línea base verificable, comprobando diseño, existencia, implementación, cobertura y eficacia de los controles relevantes sin rehacer innecesariamente lo que ya se encuentre implementado. Esta auditoría debería coordinarse con una evaluación de los controles de seguridad bajo ISO/IEC 27002:2022, de modo que los hallazgos legales y técnicos se integren en un único plan de mejora basado en riesgos.

8.1 Alcance recomendado

- Gobierno, responsabilidad proactiva, DPD, independencia, recursos, reportes y revisión por dirección.
- Inventario de tratamientos, RAT, finalidades, bases de legitimación, categorías de datos, conservación y gestión de cambios.
- Transparencia, consentimientos cuando corresponda, canales físicos/digitales y ejercicio de derechos.
- Seguridad lógica, física y organizativa; pruebas de acceso, MFA, logs, respaldo, vulnerabilidades, dispositivos y bajas.
- Incidentes y vulneraciones: severidad, escalamiento, preservación de evidencia, decisión de notificación, lecciones aprendidas y simulacro.
- Encargados, contratos, nube, soporte técnico, subencargados, transferencias y terminación de servicios.
- Riesgos, EIPD, LIA, privacidad desde el diseño, anonimización/seudonimización cuando corresponda.
- Capacitación, auditoría interna, indicadores, acciones correctivas y mejora continua.

8.2 Evidencia mínima a solicitar

- Política y control maestro documental; actas de aprobación y comunicación.
- Nombramiento/registro y reportes del DPD; organigrama, independencia y seguimiento de recomendaciones.
- Inventario de datos/tratamientos y RAT; matriz de bases de legitimación; tabla de conservación.
- Avisos de privacidad y formularios; registro de solicitudes de derechos y muestras de casos cerrados.
- Matriz de accesos, usuarios privilegiados, MFA, respaldos/restauraciones, logs y gestión de vulnerabilidades.
- Procedimiento y bitácora de incidentes; criterios de severidad; evidencias de casos y simulacros.
- Registro de riesgos, EIPD, LIA y controles de privacidad desde el diseño.
- Matriz de proveedores, contratos/DPA, subencargados, transferencias, accesos de soporte y evidencias de salida.
- Plan de capacitación, evaluaciones, auditoría interna, plan de acciones correctivas y actas de revisión por dirección.

9. Recomendación complementaria: Auditoría de controles ISO/IEC 27002:2022

El resultado de la dimensión Seguridad de datos personales (85,6%, Nivel 4) constituye una señal favorable dentro del assessment. Dado que esta fase fue exploratoria y no contempló revisión de configuraciones, registros, respaldos, restauraciones, vulnerabilidades, monitoreo, cifrado ni pruebas de efectividad, el siguiente paso natural es validar técnicamente una muestra de controles de seguridad, coordinada con la Auditoría de Cumplimiento LOPDP.

9.1 Enfoque recomendado

SMARTCIDI recomienda ejecutar un programa de auditoría integrado en dos frentes: (i) cumplimiento de obligaciones LOPDP y normativa aplicable; y (ii) diseño, implementación y eficacia de los controles de seguridad aplicables, tomando ISO/IEC 27002:2022 como referencia técnica. La auditoría debe generar una sola matriz de hallazgos, riesgos, evidencia, responsables y acciones correctivas, evitando evaluaciones aisladas entre Jurídico, Seguridad de la Información y Tecnología.

La LOPDP exige implementar medidas administrativas, técnicas, físicas, organizativas y jurídicas apropiadas y someterlas a verificación y evaluación periódica de su eficacia. ISO/IEC 27002:2022 resulta útil para estructurar esa revisión técnica, pero no sustituye las obligaciones legales de la LOPDP.

9.2 Alcance de controles ISO/IEC 27002:2022

- Controles organizacionales (cláusula 5; 37 controles): gobierno de seguridad, roles y segregación, inventario y clasificación de información, transferencias, identidades y accesos, proveedores y nube, incidentes, continuidad, requisitos legales, privacidad, revisión independiente, cumplimiento y procedimientos documentados.
- Controles de personas (cláusula 6; 8 controles): selección, condiciones laborales, concienciación y capacitación, responsabilidades disciplinarias y de salida, confidencialidad, trabajo remoto y reporte de eventos de seguridad.
- Controles físicos (cláusula 7; 14 controles): perímetros y accesos físicos, áreas seguras, monitoreo físico, amenazas ambientales, puesto de trabajo, equipos, activos fuera de instalaciones, medios de almacenamiento, servicios de soporte, cableado, mantenimiento y disposición segura.
- Controles tecnológicos (cláusula 8; 34 controles): endpoints, privilegios, restricciones de acceso y autenticación, protección contra malware, vulnerabilidades y configuraciones, eliminación y enmascaramiento, prevención de fuga, respaldos, registros y monitoreo, redes, criptografía, desarrollo seguro, pruebas, cambios y protección de información durante actividades de auditoría.

La revisión debe considerar la aplicabilidad de los 93 controles de la norma, documentando los controles aplicables y las exclusiones justificadas según riesgo, contexto, tecnología, terceros y obligaciones de la Cooperativa. No se recomienda aplicar los controles de forma mecánica ni considerar su mera existencia documental como prueba de eficacia.

9.3 Controles que requieren prioridad en la Cooperativa

- Identidad, autenticación y privilegios: altas, cambios y bajas; MFA; cuentas privilegiadas; segregación y revisión periódica de accesos.
- Registro, monitoreo y evidencia: logs de sistemas críticos, trazabilidad de administradores, sincronización de tiempo, retención y protección de registros.
- Respaldo y recuperación: política de respaldos, cobertura de información crítica, pruebas de restauración, RPO/RTO definidos cuando corresponda y evidencia de resultados.
- Gestión de vulnerabilidades y configuraciones: inventario técnico, parchado, endurecimiento, escaneo, excepciones, seguimiento y evidencias de cierre.
- Proveedores, nube y soporte: requisitos de seguridad, accesos remotos, subcontratación, cambios, monitoreo del servicio, terminación y devolución/eliminación de información.
- Incidentes y preservación de evidencia: clasificación, escalamiento, contención, cadena de custodia/evidencia, lecciones aprendidas y coordinación con obligaciones de notificación LOPDP.

- Conservación y eliminación segura: eliminación en sistemas, bases, respaldos y medios; disposición o reutilización de equipos; coherencia con la tabla de conservación.
- Revisión independiente y mejora: auditorías, seguimiento de acciones correctivas, indicadores y revisión por dirección, actualmente identificados como puntos débiles del assessment.

9.4 Metodología mínima de auditoría

- Revisión de políticas, estándares, procedimientos, matrices, registros y evidencias de aprobación/vigencia.
- Entrevistas de corroboración con responsables de procesos, TI, Seguridad, Jurídico, Riesgos, Talento Humano y terceros críticos cuando corresponda.
- Muestreo basado en riesgo de usuarios, accesos, incidentes, respaldos, proveedores, cambios, vulnerabilidades y tratamientos de datos personales.
- Pruebas técnicas y de efectividad sobre una muestra representativa de controles críticos, sin limitarse a la revisión documental.
- Clasificación de hallazgos por criticidad, causa, impacto, evidencia, requisito relacionado, responsable y fecha objetivo de remediación.

9.5 Entregables recomendados

- Informe de Auditoría de Cumplimiento LOPDP con hallazgos respaldados por evidencia y nivel de riesgo.
- Matriz de aplicabilidad y evaluación de controles ISO/IEC 27002:2022, con justificación de controles aplicables/no aplicables y resultado de las pruebas ejecutadas.
- Matriz integrada de hallazgos LOPDP - seguridad de la información, evitando duplicidades y vinculando cada brecha con tratamiento, activo, riesgo y evidencia.
- Plan de remediación priorizado a 30/60/90 días y hoja de ruta de mediano plazo, con responsables, fechas, dependencia y evidencia requerida para cierre.
- Resumen ejecutivo para Gerencia/Directorío que diferencie cumplimiento legal, eficacia de controles, riesgo residual y decisiones pendientes.

Nota técnica: ISO/IEC 27002:2022 es una guía de controles y no un estándar de certificación. Si la Cooperativa decide avanzar hacia una certificación formal de su Sistema de Gestión de Seguridad de la Información, el estándar de requisitos a considerar es ISO/IEC 27001:2022.

10. Conclusión

El assessment cumple su propósito como diagnóstico inicial: ofrece una radiografía de las prácticas reportadas, identifica fortalezas percibidas y señala áreas que requieren mayor profundidad. Dado su alcance exploratorio, no corresponde interpretarlo como auditoría ni como una conclusión definitiva de cumplimiento. El siguiente paso recomendado es una Auditoría de Cumplimiento LOPDP basada en evidencia, complementada con la evaluación de controles aplicables de ISO/IEC 27002:2022, para establecer una línea base verificable y un plan de mejora priorizado por riesgo.

Próximo paso recomendado

Ejecutar una Auditoría Integrada de Cumplimiento LOPDP y evaluación de controles de seguridad con referencia a ISO/IEC 27002:2022, utilizando el assessment como mapa inicial de prioridades. La auditoría deberá basarse en evidencia, muestreo y pruebas de efectividad, con foco en los controles estructurales LOPDP, los tratamientos financieros de mayor impacto y los controles que protegen confidencialidad, integridad, disponibilidad y trazabilidad. El resultado debe convertirse en una línea base verificable y en un plan formal de mejora.

Atentamente;

Ing. Aleczandra Villavicencio V
SMARTCIDI
avillavicencio@smartcidi.com
+593999723828